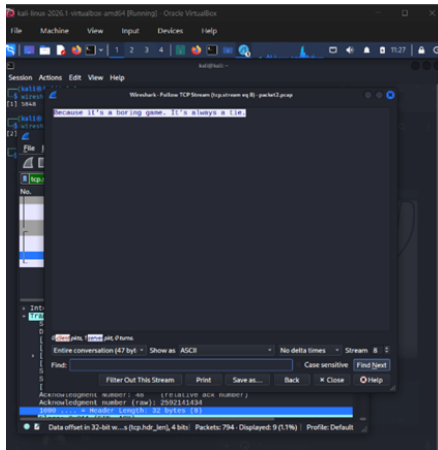


Lab 7 - Scanning Result

Name : Elis Karisha binti Kamarul Hisam
52215125885

Question 2: Packet Analysis

1. Analysis of packet2.pcap



Answer : The hidden message is “Beuase its a boring game. It’s always a tie”

Question 3: Interpretation of Nmap Output

1. Attacker Action Matrix per Port

Port / Protocol	Service Version	Potential Attacker Actions PDF
21/tcp	vsftpd 2.3.4	Exploit a built-in application backdoor to spawn an unauthenticated root shell.

22/tcp	OpenSSH 5.3p1	Conduct user enumeration scans or launch targeted SSH credential brute-force attacks.
80/tcp	Apache 2.2.8	Map web directories, look for configuration flaws, or launch legacy Denial of Service (DoS) vectors.
139/tcp	netbios-ssn	Enumerate network shares and harvest netbios names.
445/tcp	Windows 7 Professional 7601 SP1	Enumerate network shares, attempt null sessions, or execute remote code execution payloads.

2. Likely Present Vulnerabilities

- **vsftpd 2.3.4:** Vulnerable to **CVE-2011-2523** (vsftpd Backdoor Command Execution), triggered by a specific byte sequence in the login username field.
- **Apache 2.2.8:** Susceptible to multiple cross-site scripting (XSS) issues and memory disclosure bugs.
- **Windows 7 Professional 7601 Service Pack 1 (SMBv1):** Critically vulnerable to **MS17-010 (EternalBlue / CVE-2017-0144)**, which targets flaws in handling specific SMBv1 request packets.

3. Highest Risk Vulnerability and Justification

- **Highest Risk Target:** Port 445 (Microsoft-DS / Windows 7 SP1).
- **Justification:** The system is running an unpatched legacy Windows 7 architecture with SMBv1 exposed. This allows an attacker to execute an **EternalBlue (MS17-010)** exploit, yielding immediate, unauthenticated **SYSTEM-level Remote Code Execution (RCE)** over the network.

4. Established Attack Path

1. **Reconnaissance:** Run targeted port scans using Nmap to fingerprint versions.
2. **Initial Weaponization:** Match port 445 to the known **MS17-010** vulnerability stack.
3. **Exploitation:** Deploy an exploit payload via the Metasploit framework targeting the SMB service.
4. **Privilege Escalation:** Gain absolute control over the kernel space (**nt authority\system**).
5. **Post-Exploitation:** Extract local credentials, establish persistence, and pivot through internal network segments.

5. Recommended Remediation Strategies

- **Disable Legacy Protocols:** Completely disable the insecure SMBv1 protocol across the infrastructure.
- **Patching:** Apply Microsoft Security Bulletin **MS17-010** immediately.
- **Service Hardening:** Upgrade **vsftpd** , **Apache** , and **OpenSSH** binaries to modern, actively supported production distributions.
- **Network Isolation:** Implement an access control list (ACL) via a network firewall to block public access to ports 21, 22, 139, and 445.

Question 4: Operating System Fingerprinting (TTL)

By evaluating the default Time-to-Live (TTL) configuration parameters from captured outbound headers, the host platforms can be categorized accurately:

- **Observed TTL Value:** 255
- **Identified OS Type:** Cisco IOS / Network Hardware Device.
- **Justification:** Network devices default to an initial loop threshold value of 255 to safely facilitate comprehensive internetwork routing. The interface label [CLIENT FastEthernet0/B to SW1 2] confirms a networking hardware connection.
- **Observed TTL Value:** 128
- **Identified OS Type:** Microsoft Windows.
- **Justification:** The ping sequence responses for host 192.168.122.239 return an explicit signature of ttl=128, confirming a standard Windows kernel network profile.

Question 5: Ghostcat Vulnerability Analysis (Network_Scan.nessus)

Based on parsing the critical vulnerability threat indicators inside the **Network_Scan.nessus** file regarding the "Ghostcat" finding:

1. **Affected Port Number:** Port 8009
2. **Affected Protocol:** AJP (Apache JServ Protocol)
3. **CVSS Score of Vulnerability:** 9.8 (Critical)
4. **Available Exploits:** Yes, reliable automated public exploit proofs-of-concept are widely distributed, notably via the standard Metasploit auxiliary and exploitation tree modules (**auxiliary/admin/http/tomcat_ghostcat**).
5. **CVE Identifier:** CVE-2020-1938